



State of Ohio IT Standard

No:
ITS-SEC-01

Data Encryption and Cryptography

Effective:
April 29, 2025

Approved By:
Katrina Flory, Assistant Director/State CIO

I. Purpose

This state IT standard defines the minimum requirements for ***Cryptographic Algorithms*** that are ***Cryptographically Strong*** and are used in ***Security Services*** that protect at-risk or ***Confidential Data*** as defined and required by agency or state policy, standard or rule. This standard does not classify data elements; does not define the security schemes and mechanisms for devices such as tape backup systems, storage systems, mobile computers or removable media; and does not identify or approve secure transmission protocols that may be used to implement security requirements. The first occurrence of a defined term in the policy body outside of a title or heading is in bold, italic type, and is hyperlinked to the definition in Section IV.

II. Scope

This policy applies to all state Agencies, boards, and commissions under the authority of the Governor (collectively referred to as Agency or Agencies) and to employees, contractors, temporary personnel and other agents of those Agencies (collectively referred to as Individuals).

III. Standard

A Security Service conforming to this state IT standard embeds validated ***Cryptographic Modules*** (see section III.A.) and uses approved Cryptographic Algorithms (see section III.B.) in its implementation. Furthermore, the description of the cryptographic implementation shall be kept confidential (see section III.C.). Any use of Cryptographic Modules for electronic signatures must also comply with rule 123:3-1-01 of the Ohio Administrative Code.

A. Approved Cryptographic Modules

1. **Validated Cryptographic Modules:** Cryptographic Modules embedded in Security Services validated under the ***Cryptographic Module Validation Program (CMVP)*** in accordance with NIST Federal Information Processing Standards (FIPS) Publication 140-2, "Security Requirements for Cryptographic Modules," are approved for use through September 21, 2026. After September 21, 2026, the remaining FIPS 140-2 certificates will be moved to the historical list.

NIST FIPS Publication 140-3, "Security Requirements for Cryptographic Modules," is approved for use. Cryptographic Module validations must be evidenced by a NIST-issued certificate number.

2. **In Process List of Cryptographic Modules:** Cryptographic Modules that are on the CMVP In Process List (refer to Section VI. Related Resources - NIST Cryptographic Module Validation Program (CMVP) Program) are approved for use by this standard, except when such deployment may be further limited or prohibited by agency or State policy, standard or rule. Submission for testing is not a guarantee of eventual validation and, consequently, may pose a security risk. Agencies should be deliberate in determining whether their use of an unvalidated Cryptographic Module is appropriate. If a Cryptographic Module that is in use is subsequently removed from the CMVP In Process List without a certificate, continued use of the Cryptographic Module must cease immediately.

- B. **Approved Cryptographic Algorithms:** The specification of a Cryptographically Strong algorithm includes the name of the approved algorithm and key length, a reference to its formal specification in a FIPS or NIST recommendation, and its acceptable use, which means that the algorithm and key length is safe to use and currently has no known security risk.

1. **Symmetric Key Ciphers for Data Encryption:** Cryptographic Modules that use a ***Symmetric Key Cipher*** (also referred to as private key encryption) employing a shared secret key must adhere to the specifications in Table 4-1.

Table 4-1. Approval Status of Symmetric Algorithms Used for Encryption and Decryption	
Algorithm Reference	Use
Advanced Encryption Standard (AES)-128, AES-192, and AES-256 Encryption and Decryption NIST FIPS Publication 197, “Advanced Encryption Standard (AES),” November 2001.	Acceptable

2. **Asymmetric Key Ciphers for Digital Signatures:** Cryptographic Modules that use ***Asymmetric Key Ciphers*** (also known as public key encryption) that employ a pair of cryptographic keys consisting of one public key and one private key must adhere to the specifications in Table 4-2.

Table 4-2. Approval Status of Algorithms Used for Signature Generation and Verification	
Algorithm Reference	Use
Digital Signature Algorithm (DSA): $\text{len}(p) \geq 2048$ and $\text{len}(q) \geq 224$ NIST FIPS PUB 186-4, “Digital Signature Standard (DSS),” July 2013.	Acceptable
Rivest, Shamir and Adleman (RSA): $\text{len}(n) \geq 2048$ NIST FIPS PUB 186-4, “Digital Signature Standard (DSS),” July 2013.	Acceptable
Elliptic Curve Digital Signature Algorithm (ECDSA) or Edwards-curve Digital Signature Algorithm (EdDSA): $\text{len}(n) \geq 224$ NIST FIPS PUB 186-4, “Digital Signature Standard (DSS),” July 2013.	Acceptable

3. **Message Authentication: Message Authentication Code (MAC)** algorithms are used to provide Security Services for data authentication and ***Integrity***. They are used to establish the origin of information in a two-way exchange and confirms that information was not changed after it was transmitted. MAC algorithms must adhere to the specifications in Table 4-3.

Table 4-3. Approval Status of Algorithms for MAC Generation and Verification	
Algorithm Reference	Use
Keyed-Hash Message Authentication Code (HMAC): Key Lengths $\geq$ 112 bits NIST FIPS PUB 198-1, “The Keyed-Hash Message Authentication Code (HMAC),” July 2008. NIST SP 800-107 Revision 1, “Recommendation for Applications Using Approved Hash Algorithms,” August 2012.	Acceptable
Cipher-based Message Authentication Code (CMAC): AES NIST SP 800-38B, “Recommendation for Block Cipher Modes of Operation: The CMAC Mode for Authentication,” October 2016.	Acceptable
Galois Message Authentication Code (GMAC): AES NIST SP 800-38D, “Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC,” November 2007.	Acceptable
KECCAK Message Authentication Code (KMAC): Key Lengths $\geq$ 112 bits NIST SP 800-185, “SHA-3 Derived Functions: cSHAKE, KMAC, TupleHash, and ParallelHash,” December 2016.	Acceptable

4. **Secure Hashing:** A secure **Hash Algorithm** can be used to support implementation of keyed-hash message authentication, digital signature algorithms, key derivation functions and random number generators. Cryptographic Modules that use a secure Hash Algorithm shall adhere to the specification in Table 4-4.

Table 4-4. Approval Status of Hash Functions	
Algorithm Reference	Use
Secure Hash Algorithm (SHA)-2 family (SHA-224, SHA-256, SHA-384, SHA-512, SHA-512/224 and SHA-512/256) NIST FIPS PUB 180-4, "Secure Hash Standard (SHS)," August 2015.	Acceptable
SHA-3 family (SHA3-224, SHA3-256, SHA3-384, and SHA3-512) NIST FIPS PUB 202, "SHA-3 Standard: Permutation-Based Hash and Extendable-Output Functions," August 2015.	Acceptable

- C. **Cryptographic Key Security:** Documents describing all implementation aspects of cryptographic key generation and management by the Security Service shall be kept confidential and are considered a "security record" for the purposes of Ohio Revised Code 149.433. These documents contain information directly used for protecting or maintaining the security of public office against attack, interference or sabotage and must be adequately protected using strong cryptographic methods.
- D. **Exceptions to the Standard:** There are no exceptions to this State of Ohio IT standard.

IV. Definitions

- A. **Asymmetric Key Cipher.** A Cryptographic Algorithm that uses two encryption keys: the private key, which is never shared and is used when the data is encrypted, and the public key, which is shared and used when the data is decrypted. One drawback with Asymmetric Key Ciphers is that they can be more computationally intense than comparably secure Symmetric Ciphers. Therefore, requiring more resources to achieve the same security.
- B. **Cipher.** A Cryptographic Algorithm used to encrypt or decrypt data.
- C. **Confidential Data.** This classification includes Data that is required to be protected by law or regulation, is intended for confidential use, and may not be copied or removed from an agency's operational control without authorized permission. This classification includes Data that, if compromised, may result in loss of life, serious injury, or other harm to an individual or group, or disruption to critical agency operations.

- D. Confidentiality. Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.¹
- E. Cryptographic Algorithm. A computational procedure that takes variable inputs, including a cryptographic key, and produces an output intended to implement a security function. There are three classes of Cryptographic Algorithms: hash functions, Symmetric Key Ciphers and Asymmetric Key Ciphers. These are defined by the number of cryptographic keys used with the algorithm (0, 1, or 2, respectively).
- F. Cryptographic Module. A combination of hardware, software and firmware that implements a Security Service using one or more Cryptographic Algorithms.
- G. Cryptographic Module Validation Program (CMVP). Cryptographic Module Validation Program (CMVP) was established by NIST and the Communications Security Establishment (CSE) of Canada in July 1995. All Cryptographic Module testing under CMVP is handled by accredited third-party testing laboratories.
- H. Cryptographically Strong. Describes a quality attribute of a security function that means, in comparison to other methods, the function has greater resistance against attack. Security functions approved in this standard are deemed Cryptographically Strong, in particular against attacks of brute force key search that intend to access the Confidential Data protected by the specified algorithms.
- I. Hash Algorithm. A function that maps a bit string of arbitrary length into a fixed length bit string. Secure hash functions are resistant to computational attacks that attempt to determine any input that maps to any pre-specified output.
- J. Integrity. Guarding against improper information modification or destruction and includes ensuring information non-repudiation and authenticity.²
- K. Message Authentication Code. A cryptographic checksum on data that uses a symmetric key to detect both accidental and intentional modifications of data.
- L. Security Service. A cryptography mechanism used to provide **Confidentiality**, data Integrity, authentication, authorization or non-repudiation of information. A Security Service is often used to protect cryptographic keying material.
- M. Symmetric Key Cipher. A Cryptographic Algorithm that uses a single key to encrypt data. In practice, the two parties that encrypt and decrypt data must agree on the encryption key in advance. Symmetric Key Ciphers can be significantly faster than Asymmetric Key Ciphers, but the necessity of exchanging keys increases their vulnerability.

¹ “NIST Special Publication 800-53 Revision 5, Security and Privacy Controls for Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, September 2020. <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>>.

² “NIST Special Publication 800-53 Revision 5, Security and Privacy Controls for Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, September 2020. <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>>.

V. Authority

ORC 125.18

VI. Resources

Document Name	Location
NIST Cryptographic Standards and Guidelines	https://csrc.nist.gov/projects/cryptographic-standards-and-guidelines
NIST Cryptographic Module Validation Program (CMVP) Program	https://csrc.nist.gov/projects/cryptographic-Module-validation-program
NIST Special Publication 800-57, "Recommendation for Key Management – Part 1: General"	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-57pt1r5.pdf
NIST Special Publication 800-131A Revision 2, "Transitioning the Use of Cryptographic Algorithms and Key Lengths"	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-131Ar2.pdf
NIST Special Publication 800-175A, "Guideline for Using Cryptographic Standards in the Federal Government: Directives, Mandates and Policies"	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-175A.pdf
NIST Special Publication 800-175B Revision 1, "Guideline for Using Cryptographic Standards in the Federal Government: Cryptographic Mechanisms"	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-175Br1.pdf

VII. Inquiries

For information regarding this standard, please contact:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 39th Floor
Columbus, Ohio 43215

1-614-644-6860 | state.isp@das.ohio.gov

State of Ohio information security and privacy standards may be found online at:
<https://ohid.ohio.gov/wps/myportal/gov/myohio/my-resources/oisp/oisp-services/information-security-privacy-standards>

VIII. Revision History

This standard shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
07/25/2007	Version 1.0, Original Standard.
03/12/2021	Revised to reflect advancements in encryption and cryptography standards. The template, branding, terminology and references were updated to align with current practices and publications.
10/13/2021	Conducted routine maintenance review of citations and references.
04/29/2025	Replaced the term sensitive data, or sensitive information, with confidential data. Updated the template.